

SEAL

PHYSICAL SECURITY

v0.1

Your friendly physical
security companion

feat. **THE RED GUILD**

Security Alliance

PHYSICAL SECURITY

v0.1

Your friendly physical
security companion

Security Alliance

Table of Contents

About this book	9
Help us improve	10
Human safety comes first	11
Introduction	12
Disclaimer	14
How this book is organized	15
The threat	17
Why this is a book now	18
Who shows up	19
What they want	21
Where they hit	22
How they pick you	24
Individual risk	24
Organizational risk	25
Place	26

Early signals	27
Design the keys	29
Five principles	30
Wallet tiers	31
Multisig, MPC, geography	33
A wallet you can hand over	34
Ceremonies and rotation	36
Protect the people	37
Digital hygiene	37
Split the identity	39
Family and staff	40
Routines	41
What you say	43
If it happens	44
Limits that buy time	44
A path that can be complied with ...	45

Life first	46
Containment when it is safe	48
Other people	49
Write it down, show it to few	50
After	51
People	51
Infrastructure.....	52
Governance	53
Watch	53
Do this next	55
Rough maturity	55
This week	56
This quarter	58
Later	59
If it is happening now	62
Active physical threat	62

Doxxing or surveillance signal	63
Device or key may be tampered	64
After, when you reset trust	65
Conclusion	66

ABOUT – SECURITY ALLIANCE

Security Alliance (SEAL) is a nonprofit organization dedicated to securing the future of cryptocurrency. Under the leadership of whitehat hacker **samczsun**, the organization designs security projects and coordinates across the crypto industry so that useful practices actually get used.

Learn more at securityalliance.org

ABOUT – THE RED GUILD

A non-profit organization, think-tank-alike, devoted to do security as a public good within the Ethereum ecosystem. Its work spans security research, responsible disclosure, education, open-source tooling, community awareness and more. It is best known for developing gamified learning experiences like **Damn Vulnerable DeFi**, and their recent platform the **Phishing Dojo**.

Learn more at theredguild.org

blog.theredguild.org · phishingdojo.com

About this book

This mini-book is a print adaptation of the Physical Security framework from the **Security Frameworks**, an initiative by the **Security Alliance**. The web pages were written for a site. This edition is rewritten for a pocket book you can hand to someone.

The source this edition follows is Coercion & Duress: the reviewed core of the current framework. Facility security, counter-surveillance, and hardware supply-chain integrity still exist online as stubs. They are not in this book. Empty chapters make a worse companion than a short one.

This print cut changes order, cuts website navigation, and turns the same controls into reading you can do on a train. It does not invent new controls to fill gaps.

Help us improve

The live framework moves. If a control here is wrong, incomplete, or now dangerous in your jurisdiction, fix it upstream so the site and the next printing match.

`github.com/
security-alliance/frameworks`

If you value this kind of resource, you can support the work at our website.

securityalliance.org/donate

Human safety comes first

No asset, key, policy, or evidence goal is worth more harm. If someone is being coerced, the job is to keep them alive and to stop the situation getting worse. Technical containment starts only when it does not put the victim, family, staff, responders, or bystanders in more danger.

Introduction

Cryptography protects keys from math. It does not protect the person who can use those keys. Wrench attacks skip the protocol and go after people: threats, kidnapping, extortion, forced signing, raids.

Self-custody and on-chain treasuries put large balances on a small number of humans. Public posts, conference badges, and leaked addresses make those humans easier to find. Most wallet guidance still talks as if the only failure is a stolen seed on a laptop.

This book is for founders, traders,

operators, signers, and the people around them. It is also for the org that will have to respond if one of those people is grabbed.

Read it as a loop, not as a policy you recite once:

1. See who can reach you, and what one person can move.
2. Design keys and roles so coercing one person is not enough.
3. Shrink what follows you around: devices, family, routines, public identity.
4. If it happens, protect life first. Move funds only when that does not raise the violence.

5. Afterward, look after people, throw away exposed material, and close the hole that was used.

Disclaimer

This is not legal advice, and it is not a close-protection course. It will not match every country, family, or treasury. Some of the dollar figures and wallet splits in later chapters are examples from the source, not defaults. Copying them blindly is how you get a setup an attacker can predict.

A hidden duress path, a fake-empty wallet, or a “surrender” balance can get someone hurt if it is obviously fake, or if it contradicts what the attacker

already saw on-chain. Design that kind of control with people who do this work. Do not invent it in a parking lot.

The contents are free on the Security Frameworks site. Suggest changes there.

How this book is organized

1. **The threat.** What a wrench attack is, who does it, what they want, where they hit.
2. **How they pick you.** Visibility, routines, concentrated signing power, early signals.
3. **Design the keys.** Minimization, split roles, delay, a believable low-

value path.

4. **Protect the people.** What follows a signer around, including family and staff.
5. **If it happens.** Life first, then limits, then containment when it is safe.
6. **After.** Support, rebuild, close the gap.
7. **Do this next.** A phased list so this does not stay theoretical.

The last chapter is four short cards for the moment you do not want to reread a section.

The threat

Cryptography and device controls stop remote and algorithmic attack. They do not stop a person with a wrench, a kidnapping crew, or a detention at a border. Physical security is the work of protecting people from that, and of making the keys they hold less useful to whoever is hurting them.

A **wrench attack** is any case where the attacker skips the protocol and goes after the human who can unlock, sign, or coerce someone else to sign. The assumption is physical reach, or a credible threat of it. Phishing and malware are different problems.

The name comes from the xkcd comic in which 4096-bit RSA loses to a cheap wrench.¹ The joke landed because it is how a lot of theft actually works.

Why this is a book now

More value sits in self-custody, non-custodial wallets, and on-chain treasuries, often on a handful of people with no institutional physical security.

Public chains, social media, and leaks make it easier to tie a real name to a balance.

Wallet documentation still spends its pages on malware and seed handling.

¹<https://xkcd.com/538/>

The physical and social path is treated as someone else's problem. It is not.

This book assumes the attacker can do basic OSINT, watch a building, and pressure a person. It does not assume a nation-state. Some of them will still use the same holes.

Who shows up

Opportunistic criminals. Local crews who learn that a target “has crypto” from lifestyle, talk, or social media. They want liquid funds fast: hot wallets, exchange apps, whatever is on the phone. Time and visible risk work against them.

Organized crime. People who combine OSINT, surveillance, and sometimes an insider. They will spend time on a founder or a treasury signer.

Insiders and the close circle. Current or former staff, contractors, partners, family, or an intimate partner. They already know where devices live, when approvals happen, and who else can sign. That knowledge is the attack.

State actors. Security services, police units, or proxies in places with weak courts or hostile enforcement. Detention, a travel stop, or a raid, used to get keys or force an on-chain action.

What they want

Direct theft. Unlock the phone, say the seed, sign the transaction.

Extortion. Keep the threat going. Personal funds and the org treasury are both in play.

Operational coercion. Pause a contract, whitelist an address, pass a malicious proposal, leak a signing policy. The wallet is the tool, not the prize.

Intelligence. Map who signs, how recovery works, where the hardware lives, so the next attempt is quieter.

Where they hit

Home. Invasions, building common areas, the parking garage, threats that name family or roommates.

Work. Treasury, ops, or engineering staff on the commute, at the office door, or in a lobby that lets visitors wander. Worse when signing devices leave the building.

Public. Cafés, airports, hotels, nightlife. Crypto conferences pack targets into one venue and tell everyone what they do.

Family, friends, staff. Spouses, children, drivers, assistants. Indirect access, or leverage.

If one person can move the treasury from the couch, the attacker does not need a clever exploit. They need that person, at home, after a public tweet.

How they pick you

Attackers do not pick randomly. They pick people who are easy to find, easy to predict, and able to move money alone.

Individual risk

Public signaling is the loudest amplifier. Founders, KOLs, traders, and engineers who post fundraising numbers, PnL, or treasury size are advertising.

Lifestyle does the rest. A repeated gym, the same café, a recognizable car, premium travel on a fixed weekday:

cheap surveillance. You do not need a skilled team to learn when someone is alone.

Signing large transactions from an unsecured home collapses the digital control and the body into one room. That is the room they want.

Organizational risk

The org version is concentrated power. If one human can authorize a material treasury movement, coercion is efficient.

It gets worse when key management is treated as an IT chore. Hiring, offboarding, travel, and family exposure

never enter the conversation. The signer goes to a conference with a hot wallet and a public badge. Nobody owned that risk because it was not a ticket in Jira.

Place

Violent crime, weak police, or corruption raises the base rate. Travel into aggressive or opaque enforcement adds a second problem: “official” coercion at a border, a hotel, or an office. The threat model for a signer in that airport is not the same as the threat model at home.

Early signals

OSINT and probing. Follower spikes, DMs that ask how treasury works, questions about routines. The same unfamiliar face near home or the office more than once.

Doxxing and threats. Harassment that names family. Posts that glue a real identity to a wallet or a balance. A leaked home or office address. That is a shift from opportunistic to targeted.

Treat those as escalation, not as internet noise. Later chapters assume you still have a window. Sometimes you do not. The point of watching is to use the window: lower what one person can move, change the routine, tell the

person you already picked for that call.

Design the keys

The point of architecture here is not elegance. It is that a coerced person, in a short window, cannot empty the thing that matters. The victim should not have to out-tough the attacker. The system should fail closed without requiring heroics.

The figures below are examples from the source, not a universal policy. Size them to your actual balances and your actual attackers.

Five principles

Minimization. Cap what any one coerced person can authorize in the time an attack usually lasts. Even full compliance should yield a loss you can survive. Make the attacker stay longer. Time is how they get caught.

Compartmentalization. Split keys, identities, devices, places, and roles. A burned hot wallet should not point at cold storage. Signers should not all live in the same city, or all report to the same person.

Controlled surrender. Give the attacker something true and small they can take now, in a range that matches what the public can already see. Keep

the real reserve behind delay and extra people, and make that delay visible. A lie that collapses under stress is worse than a small honest wallet.

Resilience. You will need to rebuild. No single backup, no single restorer, no blame circus that leaks the rest of the story.

Prioritization. Human safety beats assets. No rule should reward physical resistance. Wallet policy yields when someone is being hurt.

Wallet tiers

Think in tiers with different jobs, not one “the wallet.”

Hot (example: 0–1%). Daily ops, gas, small payments. Strict daily limits. No path from here into cold.

Warm (example: 1–5%). A few days of payroll or vendors. Extra approval and delay as size grows.

Cold (example: 5–25%). Hours to a few days, hardware signers, stored off the home and the office.

Deep-cold (the rest). Strategic reserve. Recovery that takes legal process or a ceremony measured in days or weeks, not a PIN in a kitchen.

Those percentages are prompts. A solo trader and a DAO treasury should not share a template.

Multisig, MPC, geography

For material movement, spread signing so that grabbing one person does not complete the payment. The source talks in ranges such as 3-of-5 or 4-of-7. The number matters less than the independence: different places, different risk, different ways of being reached.

MPC is the same idea with shares instead of distinct keys. The requirement is identical. No single share spends.

Do not keep hardware wallets, seeds, or signer devices at the primary residence. Home is where wrench attacks happen. Temporary hot access via a secure element is a different

problem from storing the reserve under the bed.

Offsite means a vault, a bank box, or a trusted location that is not on your daily loop. Deep-cold can be an institutional custodian. Protocol treasuries can add timelocks, pause, or an emergency path that a coerced admin cannot skip.

A wallet you can hand over

Keep one wallet whose balance you can surrender without lying, sized to look real against public activity. The source's example range is a few thousand dollars, plus a pre-funded exchange account around \$10k for

personas that would plausibly have one. Again: examples. A public trader with obvious volume cannot hand over \$400 and expect to be believed.

Make the real reserve's delay obvious. Timelocks and extra signers the attacker can see. The goal is to remove the incentive to keep hitting you for the rest.

If the device supports a duress PIN, wire it to a silent alert for a pre-agreed contact. Silent means no extra call or text the attacker watches you send. This is the control that gets people killed when it is amateurish. Rehearse it with people who do crisis work, or do not use it.

Ceremonies and rotation

Generate material in a place that is not anyone's house, with more than one person, and without a whole seed sitting on a table. Split shards. Record the ceremony if your threat model wants an audit trail.

Review who can still sign. Refresh hardware on a calendar, and after travel that raised the physical risk. After an incident, assume a 24-hour replacement path already exists. Inventing one while someone is in hospital is how you reuse a compromised signer.

Protect the people

Keys follow people. If the public identity, the family WhatsApp, the daily-driver phone, and the signer are the same blob, the architecture in the last chapter is decoration.

The work here is shrinking what an attacker can learn, and what they can grab that is standing next to you.

Digital hygiene

Stop feeding OSINT. Home address, plates, the gym in the background, geotagged photos. Use throwaway

numbers and mail for things that do not need your real identity. Full PII removal often needs a company or a lawyer, not a browser extension. Decide what exposure you will accept before you buy a cleanup service.

Harden the devices that travel with you. Full-disk encryption. No seeds, no wallet apps on the phone you take to dinner. No cloud sync of the sensitive set. Factory-reset operational devices on a schedule if they leave your sight.

Do not glue KYC to the public handle. Where the law allows, keep the trading persona and the legal identity from sitting in one screenshot.

Split the identity

Public posting and asset control should not share a phone, an email, or a SIM.

A public phone for social and travel. A signer phone that does not ride in the same pocket, and does not come to the conference.

Family: no joint public profiles that map the household. Separate devices. A simple rule that crypto holdings and signing routines are not dinner conversation.

Cold keys do not travel on your body and they do not live in a drawer on your route. Hardware and seed backups sit in different places, none of

which is “the apartment.”

Family and staff

Give the household one boring protocol they can actually remember. Something like: if a stranger asks about money or crypto, say nothing and send the pre-agreed word to the pre-agreed person. Rehearse it once. Fancy duress theatre that nobody remembers is not a protocol.

Drivers and assistants: vary routes, report being followed, do not discuss assets or locations. Tabletop the house and the office. NDAs do not replace drills.

Children get age-appropriate rules, not a lecture on MPC. Door codes, pickup codes, an assembly point.

Panic hardware in a house or a car only helps if a monitoring path exists and someone will answer it. Buying the button is not the control.

Routines

Rotate the obvious loops. Do not make solo late-night trips a habit if you are an obvious target. Ride-shares do not need your legal name on the account the attacker can already see. Do not carry a visible wad of cash because you “might need it.”

Home hardening in the source is basic: doors, windows, cameras that actually alert someone, nothing that advertises crypto on the shelf. This book will not pretend that is a facility-security manual. It is the minimum so that the rest of the design is not sitting behind a cardboard door.

Travel: no signing on the trip if you can avoid it. Someone trusted knows the itinerary. Devices in a safe are still in a safe a hotel staffer can open. Skip the high-profile side event if you are going alone and angry-online.

What you say

Probes get a boring answer. “I don’t handle that.” “Ask the company.”
Never confirm or deny holdings to a curious stranger.

Cover stories have to be the same across family and staff. “It’s in custody” and “the team runs treasury” only work if nobody at the table contradicts them. If the on-chain activity makes the story stupid, do not use it.

Once a quarter, look at what a stranger can already see: profiles, address clustering, who on staff still has access. Pay someone else to do it if you are the person who posted the fundraising thread.

If it happens

Two clocks run at once. The human clock is first. The chain clock is second, and only if speeding it up does not make the first one worse.

Limits that buy time

Hard caps on hot and warm wallets so a coerced session cannot drain the reserve.

Extra approval once a transfer crosses a line, even if the request looks like payroll. Send that approval on a different channel, to a different person, on

a different device. One compromised chat should not complete the payment.

Delay on large moves. The attacker has to keep control. That is when someone else can notice.

Request and approval should not live on the same phone. High-privilege signers should not be in the backpack you take to the airport. Geographic spread means a local incident cannot collect every signature that night.

A path that can be complied with

Keep a low-value path that can satisfy an attacker quickly and does not

upgrade into cold. It has to match the target's public life well enough to survive a glance at a block explorer. It must not be a stepping stone.

During travel, lower the limits and raise the approvals on purpose. Credible threats, doxxing, or repeated unfamiliar surveillance are the same trigger: shrink what the org can do until you understand the situation.

Life first

Treat it as a life-safety emergency. Assume the victim is still being watched or still under threat.

Activate one crisis channel and one in-

cident commander. Split brains make this worse. If kidnap-and-ransom insurance exists, call that team. Reputable policies come with negotiators. Do not crowdsource this in a group chat.

Try to learn what the attacker likely already has: phones, seeds, which signer, which room.

Do not instruct resistance while someone is being hurt. Move people to safety, get medical care, then debrief. If this started as travel, assume device seizure or detention and get local legal help before you play incident-responder on Telegram.

Containment when it is safe

When the violence is no longer the current problem:

Rotate or disable signers. Move what is still exposed into a contingency path you already built.

If contracts can pause, timelock, or restrict admin functions, consider it. Coercion is a way to pass an upgrade, not only a way to steal a hot wallet.

Assume every secret on an unlocked device is gone. Rebuild on clean hardware. Do not “just change the PIN.”

Other people

Custodians, exchanges, vendors: use the escalation path you wrote down beforehand. Block movements. Write down what you asked them to do.

Law enforcement through counsel and a crisis team, in a way that does not publish the victim's location or the remaining signers.

Insurance notice per the policy, without dumping signer maps into an email that will be forwarded.

Write it down, show it to few

Keep hashes, times, messages, device state. Keep a log of who decided what. Both are for later. Neither is for the company all-hands.

Need-to-know is a safety control here. Extra readers become extra targets.

When the immediate incident is over, the next chapter starts. Do not skip the people and jump to a new seed ceremony because it feels like action.

After

Recovery is two jobs. Rebuild trust in the keys. Look after the humans the keys almost got killed.

People

Counseling is not a perk. Victims and families need it.

Ask, honestly, whether this person can still be a key-holder. Their profile is now higher. Wanting to “get back to normal” is not an answer.

Tell the rest of the team what changed and what support exists. Silence reads

as “we will burn the next signer too.”

Infrastructure

Do not reuse seeds, keys, or devices that were physically reachable, including the ones that “look fine.”

Build a new hierarchy. Move remaining assets only after that hierarchy is real.

Re-check every signer, threshold, and allowlist. Incidents are a good time to insert an attacker-controlled address. Look.

Governance

Change the travel, remote-work, and high-value payment rules that actually got used against you. Write the lesson into the risk register and into onboarding so the next hire is not told folklore.

Watch

Monitor the people who were hit, and the new wallets, for follow-on surveillance or a second attempt.

Re-read the threat. The attacker who already succeeded once has a cheaper second shot.

If you have physical-security or threat-intel partners, this is when you keep them. Dropping the retainer after the news cycle is how the sequel gets written.

Do this next

If the rest of the book stayed abstract, this chapter is the order of work. Numbers are examples. Replace them with limits that match your balances.

Rough maturity

Basic / high risk. Single-factor cold, no daily limits, ad-hoc signing, loud public profile.

Intermediate. Multisig or MPC on treasury, some limits, a separate signing device, some staff who have been told the safety-first rule.

Advanced. Keys in more than one place, real role separation, time-locked reserve, drills, someone watching the wallets.

This week

Individual

Take wallet apps, exchange apps, seeds, and screenshots off the daily phone and laptop.

Put a hard daily limit on hot funds. The source example is under \$10k equivalent. Move the rest off that device.

Stand up one small wallet you can surrender without lying, and only then

consider a duress PIN that silently alerts someone who already agreed to be that someone.

Walk the house and the office. If a stranger would see a hardware wallet or a recovery sheet, it moves today.

Organization

List every active signer.

Confirm that no single person can move more than a small slice of treasury without a second human. The source example is 1–5%.

Brief the people who would be in the room. Safety first. No improvising resistance from a Slack thread.

This quarter

Individual

Split public identity from asset control:
other email, other SIM, other device.

Put cold storage in a scheme where
keys are not in one place.

Pick the trusted contact or the security
service for a panic path, and actually
tell them.

Organization

Name the job of each tier. Hot, warm,
cold. Automatic limits.

Distribute signing by geography and by function, not by who happens to have a Ledger in a drawer.

Write down how new operational keys are born and backed up. Run that process once on purpose.

Put wallet and coercion training in onboarding, not in a wiki nobody opens.

Later

Individual

Clean the obvious OSINT: address, family, travel, social.

If travel is part of the job, use a physical-security shop for that, not a group chat.

Legal structure that hides ownership is a lawyer problem, not a Twitter problem.

K&R insurance that understands crypto, if the profile warrants it. The useful part is often the negotiator, not the PDF.

Organization

Quarterly tabletops: coercion, kidnapping, insider.

Watch treasury wallets for movement that does not match the policy.

Retain people who already know this incident type.

Pay for tests against the technical path and against staff, separately. One pentest that never leaves the staging cluster will not find the signer who talks in Ubers.

If it is happening now

These are prompts, not a local emergency plan. Read them before you need them.

Active physical threat

1. Protect life. De-escalate. Do not instruct resistance.
2. Assume the victim is still watched or still coerced.
3. One crisis channel. One incident commander. Only when that call itself is safe.

4. Move people. Get medical help.
5. Contain signers, funds, contracts, and credentials only if that does not raise the physical risk.

Doxxing or surveillance signal

1. Family-specific threats, leaked addresses, persistent probing, and the same unknown face again are escalation, not vibes.
2. Lower what people can transact. Cut high-privilege work.
3. Change the exposed routine. Tell the contact you already named.

4. Keep evidence. Do not confront or follow anyone.
5. Reassess home, work, travel, and signers together, not as four tickets.

Device or key may be tampered

1. Stop using it to sign or recover.
2. Isolate it. Do not smash the evidence.
3. Treat secrets on an unlocked device as gone.
4. Rebuild on trusted hardware with new material.
5. Migrate only after the replacement actually works.

After, when you reset trust

1. Support victims and families before you demand a debrief.
2. Never reuse exposed seeds, keys, credentials, or devices.
3. Re-verify signers, thresholds, allowlists, recovery, vendors.
4. Record decisions on a need-to-know list.
5. Update the risk register, training, travel rules, and the drill calendar.

Conclusion

Physical security for key-holders is not toughness. It is deciding, in daylight, what one person is allowed to move, what follows them around, and who you will call if that person is no longer free to speak.

The less any one human can authorize, the less useful they are to grab. The less of your life is posted, the harder you are to find. The more delay and extra people you put on the reserve, the less an attacker gains by staying violent.

None of this is a checklist you tick in

January. Limits drift. New signers join. Someone starts tweeting numbers again. Re-read the threat when the org changes, when someone becomes famous, when a conference week is coming.

If something already happened, do not reuse the compromised path because it is familiar. Look after the people first. Then rebuild from material that was never in that room.

You will not get this perfect. The job is to make coercion expensive, recovery possible, and panic unnecessary. Keep the authority small. Keep the humans alive. Move through the world without advertising the keys.

ACKNOWLEDGMENTS

This pocket book was written by mattaereal and scode2277. The pages follow the Physical Security framework, whose current steward and top contributor is AllyPry.

Current stewards for other frameworks:

AI Security. curtis0x, masterfung, munamwasi

Community Management. NFTDreww

DNS & Domain Registration Security.

Raiders

DevSecOps. Elliot

ENS. Ghadi Mhawej

Incident Management. EK, Nick K

Monitoring. Josep Bove

Operational Security. Seth Hallem

Safe Harbor. Dickson Wu

SEAL Certs. Dickson Wu, Isaac Patka

Security Testing. Patrick Collins

Wallet Security. Piña

SOURCE SNAPSHOT

This cut follows the Coercion & Duress pages of the Security Alliance Physical Security framework. Website navigation, in-progress stubs, and further-reading links are not in the book.

Branch develop

Commit bc6f17a4c04c

Commit date 2026-09-09

Build date 2026-09-13

Online frameworks.securityalliance.org

Framework authors in this snapshot

AllyPry, mattaereal, scode2277

Check the site before you treat this as current.

@ 2026 Security Alliance / The Red Guild

Security Frameworks copyright 2023–2026 Security Alliance and contributors. This pocket edition is Creative Commons Attribution-ShareAlike 4.0 International.

creativecommons.org/licenses/by-sa/4.0/

Share and adapt, including commercially, if you give credit, say what changed, link the license, and keep adaptations under the same license.

Gentium Book is SIL OFL 1.1. Latin Modern is GUST Font License.

Pocket edition – 2026

Published by Security Alliance (SEAL) · The Red Guild